

CSRF QA Testing Checklist

ISEC3004 - Cyber Crime and Security Enhanced Programming

Component: CSRF Protection – Change Email Functionality
Mitigation: Synchronizer Token Pattern
Tester: Ameli Jithmini
Purpose: Verify that legitimate requests containing a valid CSRF token are accepted while malicious requests with missing or invalid CSRF tokens are rejected.

Test Checklist

Test ID	Test Scenario	Test / Input	Expected Result	Actual Result	Status
CSRF-QA-01	Legitimate email change with valid CSRF token	Submit the Change Email form normally while authenticated. The request includes the valid session CSRF token.	The request is accepted, and the email address is updated.	The legitimate request was accepted, and the email address was successfully updated.	PASS
CSRF-QA-02	Malicious request without CSRF token	Send a POST request to /change-email without the csrf_token parameter.	The server rejects the request with HTTP 403 Forbidden.	The malicious request was rejected with HTTP 403 Forbidden.	PASS
CSRF-QA-03	Malicious CSRF attack cannot change user data	Attempt to change the victim's email using a request that does not contain a valid synchronizer token.	The attack fails, and the victim's email remains unchanged.	The attack was blocked, and the email remained unchanged.	PASS
CSRF-QA-04	A valid CSRF token is present in a legitimate request	Inspect the legitimate /change-email POST request using Burp Suite.	The request contains a csrf_token value generated for the authenticated session.	Burp Suite captured the legitimate request containing the CSRF token.	PASS

CSRF-QA-05	Blocked malicious request is traceable	Send the malicious request and inspect the application/server output.	The application rejects the invalid request and records evidence explaining the blocked attempt.	Server output showed "CSRF ATTACK BLOCKED", identified a missing or invalid CSRF token, and returned HTTP 403.	PASS
------------	--	---	--	--	-------------

Overall Result: PASS - The Synchronizer Token Pattern allows legitimate requests containing the valid CSRF token and rejects malicious requests that do not contain a valid token. The blocked attack returned HTTP 403 and did not modify the user's email.

Evidence: Burp Suite request/response captures, application state screenshots, and server output collected during CSRF tracing and mitigation verification.

Note: This checklist records the tests already performed during the CSRF mitigation and verification work. It does not claim a separate fake-token test that was not independently demonstrated.